Lab04 – Threat Modeling

Kyle Potchka
September 14, 2026

1. Introduction

Threat modeling is the process of systematically identifying what requires protection in a system, potential adversaries, realistic attack methods, and actionable steps to reduce risk before an incident occurs. This approach shifts security from a reactive stance, which involves responding after an event, to a proactive strategy where risks are prioritized and mitigated based on their likelihood and potential impact.

In this report, I apply the threat modeling process to my personal computer: a Windows desktop used for schoolwork (including the virtual lab environment for this course), personal photos and files, and financial accounts. The objective is to follow the seven steps a security professional would use on a corporate network—identifying assets, threat actors, attack vectors, assessing risk, planning mitigations, and compiling a comprehensive threat model—adapted to the context of a single personal device used daily.

2. Identify Assets

The assets on my desktop that would be affected in the event of a compromise can be categorized as follows:

- Financial accounts: online banking sessions, saved payment information in the browser, and any tax or financial documents stored locally.
- Schoolwork and this course's lab environment: coursework files, login credentials for school systems, and the Kali/Metasploitable virtual lab I use for this class, which itself contains configuration details and, if compromised, could be used as a launching point against other systems on my network.
- Personal photos and files: documents and photos that aren't replaceable if lost and that I wouldn't want exposed publicly if stolen.

Financial data represents the most valuable asset to an attacker due to its immediate potential for monetization. While personal photos and files may hold less financial value to a criminal, their exposure or loss would be highly detrimental to me. The lab environment, although a smaller asset, remains significant; it operates with elevated privileges (sudo access on Kali) and contains intentionally vulnerable services (Metasploitable). If not properly isolated, an attacker could exploit this environment as a pivot point to access my broader network.

3. Identify Threat Actors

A personal computer such as mine is typically exposed to a narrower and less sophisticated range of threat actors compared to a corporate network; however, the same categories of threat actors remain relevant:

Opportunistic cybercriminals

Financially motivated attackers may not target me specifically but often conduct automated campaigns, such as credential-stuffing bots that test leaked username and password pairs against banking and email sites, or

ransomware operators who compromise users through malicious attachments. My primary vulnerability to this group is password reuse (discussed below), which is frequently exploited in credential-stuffing attacks.

Phishing / social engineering actors

These attackers distribute fraudulent login pages, counterfeit shipping notifications, or urgent emails intended to elicit credentials or prompt clicks on malicious links. Although I have not personally fallen victim to such attempts, primarily due to my practice of avoiding links in unsolicited emails, this threat category remains significant as it is a common method for compromising personal accounts.

Malware / drive-by attackers

These actors utilize infected downloads, malicious advertisements, or compromised websites to install malware, often requiring minimal user interaction beyond visiting a webpage or executing an installer. Additionally, the use of public Wi-Fi (discussed below) increases exposure to a related risk: attackers on the same network may intercept or manipulate network traffic rather than directly delivering malware.

Insiders/people with physical access

Individuals with physical access to the computer, such as roommates, family members, or others present in the household, constitute a lower-probability but non-negligible threat. This risk ranges from unauthorized use while the device is logged in to potential theft by a repair technician or other individuals.

4. Identify Attack Vectors

The following outlines how these identified threat actors could exploit vulnerabilities specific to my setup:

- Password reuse: I currently use identical passwords across multiple sites. If any of these sites are breached, attackers may attempt to use the same credentials to access my email, banking, or school accounts (credential stuffing). This represents the most significant attack vector identified in this report.
- Public Wi-Fi: I utilize public Wi-Fi networks (such as those in coffee shops or on campus). On open or inadequately secured networks, traffic may be intercepted, or credentials may be captured by a rogue access point, particularly when accessing sites that lack comprehensive end-to-end encryption.
- Phishing emails: Although I have not been deceived by phishing attempts, this vector remains a persistent risk, particularly during lapses in vigilance. Phishing is among the most common methods by which credentials and malware are introduced to personal devices.
- Outdated software: Unpatched operating system or application vulnerabilities are a frequent vector for malware, requiring no user error beyond failing to update software in a timely manner.
- Physical access: an unlocked, unattended desktop is accessible to anyone in the house, and a stolen or lost device is fully exposed unless the disk itself is encrypted.

5. Risk Assessment

Rating each identified threat by likelihood and impact:

Threat / Attack Vector	Likelihood	Impact	Risk Level
Password reuse leading to credential stuffing	High	High	High
Public Wi-Fi interception	Medium	Medium	Medium
Phishing email	Low	High	Medium
Outdated/unpatched software	Medium	Medium	Medium
Physical access/device theft	Low	Medium	Low

Password reuse is assessed as a high risk due to its current prevalence in my practices (high likelihood) and the potential for cascading compromise across multiple accounts, particularly where two-factor authentication (2FA) is not enabled (high impact). Phishing is rated as a medium risk overall; although its potential impact is significant, my current habits reduce the likelihood of successful exploitation. Physical access is considered the lowest risk, as the device remains in a private residence rather than a shared or public environment.

6. Mitigation Strategies

For each High and Medium risk identified above:

- Password reuse (High): I will adopt a password manager (such as Bitwarden or 1Password) and generate unique passwords for every account, prioritizing financial and email accounts. This approach directly mitigates the risk of credential-stuffing attacks, regardless of breaches on other platforms.
- Public Wi-Fi (Medium): use a VPN when connecting to public networks and avoid logging into financial accounts at all whiles on an untrusted network. Most modern sites use HTTPS by default, but a VPN adds a layer of protection against network-level interception and rogue access points.
- Phishing (Medium): I will maintain my current practice of avoiding links in unsolicited emails and will also verify the destination URL by hovering over links before clicking, even when messages appear to originate from legitimate sources.
- Outdated software (Medium): I will enable automatic updates for Windows and all browsers or software with internet-facing components and ensure that Windows Defender remains active and up to date.
- Physical access/theft (Low but easily addressed): I will enable full-disk encryption (BitLocker) and configure the system to lock automatically after a brief period of inactivity. These measures ensure that theft or unauthorized physical access does not result in complete data exposure.

Two existing measures are already in place and should be maintained: Windows Defender is active, and two-factor authentication (2FA) is enabled on my primary accounts. Notably, 2FA significantly reduces the practical impact of password reuse, as a compromised password alone is insufficient for account access. However, 2FA is not a complete substitute for addressing password reuse, since not all accounts are protected by this measure.

7. Threat Model Summary

Compiling the findings above into a single threat model:

Asset	Threat Actor	Attack Vector	Risk	Mitigation

Financial accounts	Opportunistic cybercriminal	Password reuse / credential stuffing	High	Unique passwords via password manager
Financial accounts, email	Opportunistic cybercriminal	Public Wi-Fi interception	Medium	VPN; avoid sensitive logins on public networks
Email, school accounts	Phishing / social engineering actor	Phishing email	Medium	Continue link-verification habits
All local data	Malware / drive-by attacker	Outdated / unpatched software	Medium	Automatic updates; keep Defender active
All local data	Insider / physical access	Device theft or unattended access	Low	Disk encryption (BitLocker); auto-lock screen

Summary Conclusion

Conducting this exercise on my own machine highlighted password reuse as the most significant risk, one that is often overlooked in daily routines. Although not a complex or technically advanced vulnerability, it currently presents the greatest exposure and is also the simplest to remediate; implementing a password manager can resolve this issue efficiently. Public Wi-Fi usage emerged as a moderate risk, primarily because I do not consistently consider it a security concern. Employing a VPN and exercising greater caution regarding accessible resources on open networks effectively mitigates this risk without necessitating the avoidance of public Wi-Fi.

Existing habits—such as avoiding unsolicited links, maintaining active Defender protection, and enabling 2FA on major accounts—proved more impactful than initially anticipated when evaluating both impact and likelihood. These practices contributed to phishing and malware being assessed as medium rather than high risks. The structured nature of this exercise, as opposed to relying on intuition, clarifies specific vulnerabilities and prioritizes effective mitigations. This methodology is directly applicable to larger environments; while a business network involves more assets, actors, and vectors, the underlying approach remains consistent.